EPICODE – Security Operation

W20D4 – Esercizio pratico: report

Luigi Valerio Pancotti

Contesto

L'applicazione di e-commerce è esposta su Internet tramite un server web posizionato in DMZ. La rete interna è raggiungibile dalla DMZ per via delle policy sul firewall: se il server in DMZ viene compromesso, un attaccante potrebbe potenzialmente raggiungere la rete interna. Di seguito le risposte ai quattro quesiti richiesti dalla traccia.

1. Azioni preventive contro SQL Injection e XSS

Per proteggere l'applicazione web da attacchi di tipo SQLi e XSS da parte di un utente malintenzionato, si propongono i seguenti controlli, da inserire tra Internet/Utenti e il server web in DMZ:

WAF (Web Application Firewall): posizionato a monte del server web (reverse proxy), filtra le richieste HTTP e blocca pattern noti di SQL Injection e Cross-Site Scripting prima che raggiungano l'applicazione.

Prepared statement / query parametrizzate: lato applicativo, eliminano la SQL Injection alla radice, separando il codice SQL dai dati inseriti dall'utente.

Input validation e output encoding: validazione rigorosa degli input lato server e codifica dell'output (escaping) su HTML/JS per neutralizzare payload XSS.

Content Security Policy (CSP): limita quali script possono essere eseguiti dal browser, riducendo l'impatto di eventuali XSS residui.

Least privilege sul database: l'utenza DB usata dall'applicazione ha solo i permessi minimi necessari (no diritti di amministrazione), limitando i danni in caso di SQLi riuscita.

SAST/DAST in CI/CD: analisi statica e dinamica del codice durante lo sviluppo per intercettare vulnerabilità prima del rilascio in produzione.

La figura seguente mostra l'architettura originale modificata con l'inserimento di questi controlli.

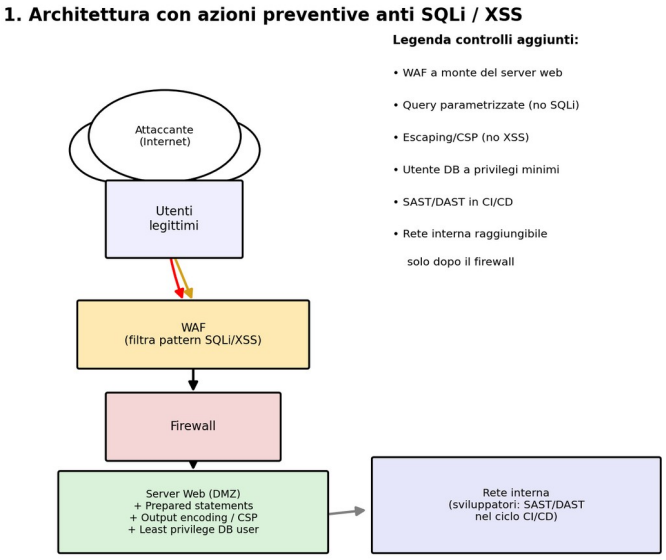


Figura 1 – Architettura con azioni preventive anti SQLi/XSS

2. Impatto sul business dell'attacco DDoS

L'applicazione subisce un attacco DDoS che la rende non raggiungibile per 10 minuti. Considerando una spesa media degli utenti di 1.500 € al minuto sulla piattaforma di e-commerce, il calcolo dell'impatto economico diretto è il seguente:

Voce	Valore
Ricavo medio al minuto	1.500 €
Durata indisponibilità	10 minuti
Mancato incasso stimato	**1.500 € × 10 = 15.000 €**

Oltre al mancato incasso diretto, vanno considerati impatti indiretti: danno reputazionale verso i clienti, possibili penali contrattuali/SLA verso partner o fornitori di servizi collegati, costi operativi del team di incident response, ed eventuale perdita di clienti verso concorrenti durante il disservizio.

Azioni preventive proposte per il DDoS

Servizio anti-DDoS / scrubbing: soluzioni come Cloudflare o AWS Shield a monte del firewall, per assorbire e filtrare il traffico malevolo prima che raggiunga l'infrastruttura.

Rate limiting: limitazione del numero di richieste per singolo IP/utente in una finestra temporale.

Load balancing e autoscaling: distribuzione del carico su più istanze con scalabilità automatica in caso di picchi di traffico.

Architettura ridondata: deployment multi-region o failover per garantire continuità del servizio anche in caso di attacco su una singola regione.

3. Response: malware sul server web

L'applicazione web viene infettata da un malware. L'obiettivo dichiarato è duplice: impedire che il malware si propaghi sulla rete interna, senza però rimuovere l'accesso dell'attaccante alla macchina infetta (per poterlo osservare e raccogliere intelligence).

La strategia di response è quindi di contenimento, non di remediation immediata:

Isolamento di rete (quarantena): l'host infetto viene spostato in un segmento di rete dedicato (VLAN di quarantena) o soggetto a regole ACL restrittive.

Blocco del movimento laterale: un firewall interno impedisce qualsiasi traffico dall'host infetto verso la rete interna e verso altri host in DMZ, mentre il traffico C2 (Command & Control) verso l'esterno viene lasciato transitare, ma sotto stretto monitoraggio.

Monitoraggio attivo: strumenti EDR/NDR sull'host infetto per registrare il traffico C2 e raccogliere Indicatori di Compromissione (IOC) utili per l'analisi forense e la threat intelligence.

Nessuna azione visibile all'attaccante: la macchina non viene spenta né disconnessa da Internet, per non insospettire l'attaccante e permettere di osservarne le tecniche (TTP).

La figura seguente mostra la modifica all'architettura: il traffico verso la rete interna viene bloccato, mentre il traffico verso l'attaccante resta aperto e monitorato.

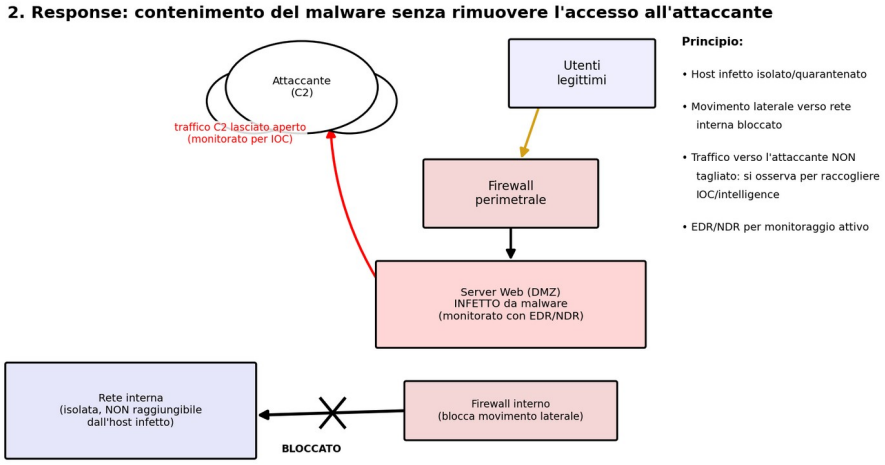


Figura 2 – Response: contenimento del malware senza rimuovere l'accesso all'attaccante

4. Soluzione completa

La soluzione finale unisce le azioni preventive (punto 1) con la strategia di response (punto 3), ottenendo un'architettura a più livelli di difesa (defense in depth):

- Anti-DDoS / rate limiting in ingresso, a protezione della disponibilità del servizio.
- WAF a monte del server web, per bloccare SQLi/XSS.
- A livello applicativo: query parametrizzate, CSP, utente DB a privilegi minimi.
- EDR/NDR attivo sul server in DMZ per rilevare compromissioni.
- Firewall interno che isola il server dalla rete interna in caso di compromissione, bloccando il movimento laterale.
- Traffico verso l'attaccante non tagliato in caso di incidente: monitorato per raccogliere IOC e intelligence.
- SAST/DAST nel ciclo di sviluppo per prevenire nuove vulnerabilità prima del rilascio.

4. Soluzione completa: azioni preventive + response integrate

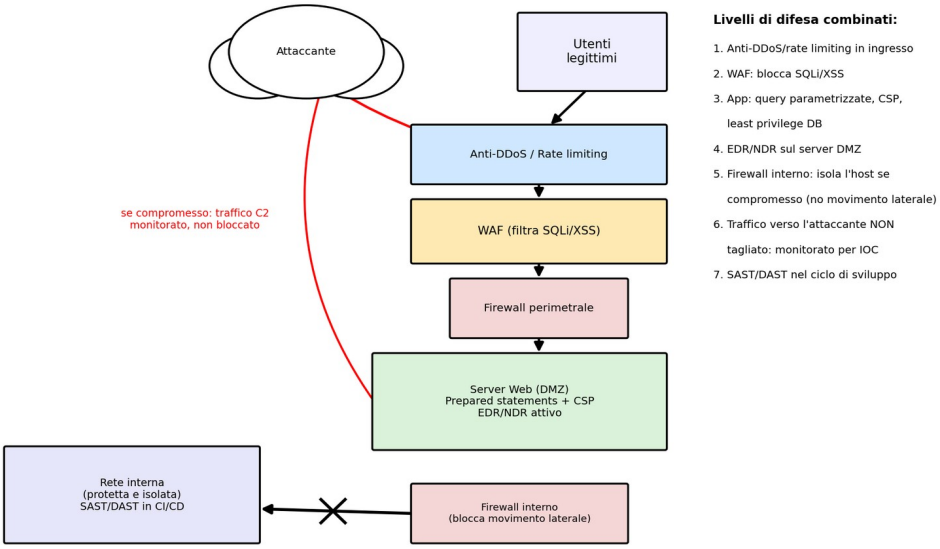


Figura 3 – Architettura completa: azioni preventive e response integrate

Conclusioni

L'architettura proposta combina prevenzione (WAF, hardening applicativo, anti-DDoS, SAST/DAST) e capacità di risposta (segmentazione, EDR/NDR, contenimento controllato) per ridurre sia la probabilità che l'impatto di un incidente di sicurezza sull'applicazione di e-commerce, mantenendo al contempo la possibilità di osservare un eventuale attaccante senza comprometterne l'individuazione.